

PRACTICAL CYBERSECURITY & COMPLIANCE SERIES

SOC 2 COMPLIANCE

A Practical Manual for Managers and Junior Analysts

How SOC 2 is planned, operated, tested, evidenced, and managed

Alberto (Al) Leiva

First Edition • July 2026

Inside: Plain-English criteria • Manager playbook • Open-source tools • Evidence examples • Junior analyst labs • Interview preparation

Publication and Use Notice

Author: Alberto (Al) Leiva

Edition: First Edition, July 2026

Purpose: Free, practical education for managers, students, career changers, junior analysts, and cybersecurity practitioners.

Educational notice

This manual provides general educational information. It is not legal advice, accounting advice, or an official interpretation of AICPA professional standards. Organizations should use the current AICPA criteria and work with qualified legal, privacy, security, and CPA professionals when preparing for an examination.

Ethical and authorized use

Only use the technical tools and exercises in this manual on systems you own or are explicitly authorized in writing to assess. Scanning, monitoring, or testing an unapproved system can disrupt service, expose information, breach contracts, or violate the law. Technical ability does not create permission.

Trademark notice

SOC 2® is a registered trademark of the American Institute of Certified Public Accountants. Product and project names belong to their respective owners. Inclusion in this manual is educational and does not imply endorsement.

Preface

A welcoming introduction to why this manual exists and how to use it.

SOC 2 can seem complicated when presented as a long list of criteria, audit requests, screenshots, policies, and technical reports. Underneath that language is a practical idea: understand what could go wrong, establish sensible controls, perform those controls consistently, and keep reliable evidence.

This manual was created for two groups who often need the same knowledge from different directions. Managers need to understand scope, ownership, risk, evidence, exceptions, and accountability. Junior analysts need to learn how to organize evidence, test controls, document results, communicate clearly, and build an honest path into compliance and assurance work.

The writing uses a clear reading level. Technical terms are introduced when they are useful and explained in plain language. The goal is not to remove professional judgment. The goal is to make that judgment easier to learn.

Like the earlier cybersecurity manuals in this series, this book follows a methodology-first approach. Tools come after purpose. A scanner can produce findings, but it cannot decide whether a control is well designed. A GRC platform can store evidence, but it cannot make weak evidence reliable. A dashboard can show a green status, but management remains responsible for what that status means.

Central lesson: SOC 2 is not a paperwork event. It is a continuing management program built around risk, controls, evidence, accountability, and improvement.

Readers are encouraged to complete the fictional laboratory projects, keep notes, ask questions, and practice explaining each topic in their own words. A person who can explain a control simply usually understands it well enough to test or manage it.

— Alberto (Al) Leiva

How to Use This Manual

Managers should begin with Chapters 1 through 6, then use the criteria, evidence, dashboard, and audit-response chapters as working references.

Junior analysts should study the criteria, evidence, tools, fictional SaaS laboratory, portfolio projects, and interview questions.

Technical readers can move directly to the open-source tools chapter, but should first understand which risk and control each tool supports.

Control owners can use the templates and checklists to prepare evidence before an auditor requests it. Teachers and mentors can use the end-of-chapter review questions and laboratory exercises for guided learning.

Word tip: The table of contents is a Word field. If page numbers do not appear immediately, right-click the table of contents and select Update Field, then Update entire table.

Table of Contents

Publication and Use Notice	2
Educational notice	2
Ethical and authorized use	2
Trademark notice.....	2
Preface	3
How to Use This Manual	4
Table of Contents	4
1. SOC 2 Foundations.....	8
1.1 What SOC 2 means	8
1.2 Attestation, not certification	8
1.3 SOC 1, SOC 2, and SOC 3	8
1.4 What SOC 2 does not guarantee	8
2. Trust Services Categories.....	9
3. Type I and Type II Reports	10
3.1 Design versus operation	10
3.2 Type II examination periods	10
3.3 The auditor's opinion	10
4. Roles and Responsibilities	11

4.1 What the manager owns	11
5. How a SOC 2 Examination Is Completed	12
5.1 Define the scope	12
5.2 Describe the system	12
5.3 Assess risk	12
5.4 Build the control matrix	12
5.5 Perform readiness	12
5.6 Remediate gaps	12
5.7 Operate controls	13
5.8 Support auditor testing	13
5.9 Evaluate exceptions	13
5.10 Issue and maintain	13
6. Scope, System Description, and Boundaries	14
6.1 The five system components	14
6.2 Subservice organizations	14
6.3 Complementary User Entity Controls	14
6.4 Description criteria	14
7. Complete Trust Services Criteria Breakdown	15
7.1 CC1 — Control Environment	15
7.2 CC2 — Communication and Information	15
7.3 CC3 — Risk Assessment	15
7.4 CC4 — Monitoring	15
7.5 CC5 — Control Activities	16
7.6 CC6 — Logical and Physical Access	16
7.7 CC7 — System Operations	16
7.8 CC8 — Change Management	16
7.9 CC9 — Risk Mitigation	17
7.10 A1 — Availability	17
7.11 PI1 — Processing Integrity	17
7.12 C1 — Confidentiality	17
7.13 P1–P8 — Privacy	17
8. Practical SOC 2 Control Library	19
8.1 Writing a testable control	19
9. Audit Evidence, Sampling, and Exceptions	21

9.1 Evidence quality	21
9.2 Populations and samples	21
9.3 Common evidence requests	21
9.4 Exceptions	22
10. Open-Source Tools for SOC 2	23
10.1 CISO Assistant	23
10.2 Wazuh	24
10.3 Prowler	24
10.4 Greenbone/OpenVAS	25
10.5 DefectDojo	25
10.6 osquery.....	26
10.7 OpenSCAP	26
10.8 Falco	27
10.9 ZAP.....	28
10.10 Trivy	28
10.11 Open Policy Agent	29
10.12 Tool governance checklist.....	29
11. Manager's SOC 2 Playbook	30
11.1 Questions for every control owner	30
11.2 Monthly dashboard	30
11.3 Status meanings	30
11.4 Common management mistakes	30
11.5 Monthly SOC 2 meeting agenda	31
12. From Beginner to Junior SOC 2/GRC Analyst	32
12.1 Job titles	32
12.2 Typical junior work.....	32
12.3 Essential knowledge.....	33
12.4 Professional skills	33
13. Fictional SaaS Laboratory and Portfolio	34
13.1 SecureCloud Learning Services.....	34
Project 1 — Scope	34
Project 2 — Risk register.....	34
Project 3 — Control matrix	34
Project 4 — Evidence package.....	34

Project 5 — Open-source tools	34
Project 6 — Control testing.....	34
13.2 Portfolio ethics	34
13.3 Honest résumé example	35
14. Thirty-Day Learning Plan.....	36
14.1 Daily habit.....	36
15. Interview Preparation	37
What is SOC 2?.....	37
Type I versus Type II?.....	37
What makes evidence reliable?	37
How would you test a termination?.....	37
What is an exception?	37
What if evidence is missing?.....	37
What is a CUEC?	37
How do tools support SOC 2?.....	37
15.1 Manager’s 60-second answer	38
16. Templates and Checklists	39
16.1 Risk register fields	39
16.2 Control matrix fields	39
16.3 Evidence-request template.....	39
16.4 Evidence review checklist.....	39
16.5 Exception record	40
16.6 Manager’s pre-audit checklist.....	40
17. Glossary.....	41
18. Subject Index.....	43
19. Official References and Further Study.....	44

1. SOC 2 Foundations

What SOC 2 is, what it is not, and why organizations request it.

1.1 What SOC 2 means

SOC 2 is an independent examination of controls at a service organization. Customers use the resulting report to understand how the organization protects information and operates the systems used to deliver its services.

SOC 2 is especially common for software-as-a-service providers, cloud services, managed services, data processors, cybersecurity providers, and other organizations that store or process customer information.

1.2 Attestation, not certification

A company is not technically ‘SOC 2 certified.’ Management makes an assertion about its system and controls, and an independent licensed CPA firm examines that assertion and issues an opinion. People often say ‘SOC 2 compliant,’ but a manager should understand the more accurate language.

Accurate statement: Our organization completed a SOC 2 Type II examination and received an independent service auditor’s report.

1.3 SOC 1, SOC 2, and SOC 3

Report	Primary purpose	Typical audience
SOC 1	Controls relevant to customers’ financial reporting	Customer management and financial auditors
SOC 2	Detailed controls relevant to security, availability, processing integrity, confidentiality, or privacy	Customers, partners, auditors, and qualified stakeholders
SOC 3	General-use summary addressing the same trust categories without the same control detail	Public distribution

1.4 What SOC 2 does not guarantee

- It does not guarantee that a security incident will never occur.
- It does not replace legal or regulatory requirements.
- It does not prove that every system in the organization was examined.
- It does not make a weak security program strong by itself.
- It does not remain current forever; readers must consider the examination period and later changes.

2. Trust Services Categories

The five areas SOC 2 can examine.



Choose categories that match the service, customer commitments, and risks

More categories mean more controls, evidence, testing, and management responsibility.

Figure 1. The five SOC 2 Trust Services Categories

Category	Plain-English meaning	Examples
Security	Protect systems and information from unauthorized access or damage.	MFA, access reviews, monitoring, vulnerability management
Availability	Keep systems operating according to commitments.	Backups, disaster recovery, uptime, capacity
Processing Integrity	Process information completely, accurately, on time, and with authorization.	Validation, reconciliation, error handling
Confidentiality	Protect information classified as confidential.	Classification, encryption, retention, deletion
Privacy	Collect, use, retain, disclose, and delete personal information properly.	Notices, consent, access requests, breach response

Security, represented by the Common Criteria, is included in every SOC 2 examination. The other categories should be selected when they match the service, customer commitments, and risks. Selecting an unnecessary category creates more controls, evidence, testing, cost, and responsibility.

3. Type I and Type II Reports

The difference between control design on a date and control operation over a period.

Report	What the auditor examines	Simple question
Type I	The description and suitability of control design as of a specified date.	Were suitable controls in place on that date?
Type II	The description, control design, and operating effectiveness throughout a specified period.	Did the controls work consistently during the period?

3.1 Design versus operation

A policy may help show that a control was designed. A sequence of completed reviews, tickets, logs, approvals, and corrective actions helps show that the control operated.

3.2 Type II examination periods

Management and the CPA firm agree on the examination period. The organization must operate the controls throughout that period. A quarterly control cannot be performed only at the end of the audit and treated as if it operated all year.

3.3 The auditor's opinion

- An unmodified opinion is the preferred result and means the report does not require a modification to the opinion.
- A qualified opinion identifies a material issue limited to a specific area.
- An adverse opinion indicates that problems are significant and widespread enough to make the subject matter materially misstated.
- A disclaimer means the auditor could not obtain enough appropriate evidence to form an opinion.

4. Roles and Responsibilities

Who owns, operates, supports, and examines the control environment.

Role	Primary responsibility
Executive management	Approve objectives, accept accountability, provide resources, and sign the management assertion.
SOC 2 program manager	Coordinate scope, controls, evidence, owners, readiness, remediation, and audit requests.
Control owner	Perform the control on time and retain reliable evidence.
IT and security	Operate technical safeguards, monitoring, vulnerability, access, backup, and incident processes.
HR	Support hiring, background checks, training, role changes, and terminations.
Legal and privacy	Interpret commitments, contracts, privacy obligations, notices, and breach requirements.
Internal audit or compliance	Perform readiness work and independent internal testing where appropriate.
Independent CPA firm	Examine management's description, assertion, and controls and issue the report.
Customers	Perform Complementary User Entity Controls identified in the report.

4.1 What the manager owns

- Define and defend the scope.
- Assign a named owner to every control.
- Approve realistic controls that match actual operations.
- Monitor control due dates and evidence quality.
- Review exceptions and corrective actions.
- Remove organizational blockers.
- Report risk honestly to leadership and the auditor.
- Keep the program operating after the report is issued.

Independence: Management designs and operates controls. The independent auditor examines them. A compliance platform or consultant cannot take management's responsibility away.

5. How a SOC 2 Examination Is Completed

A complete lifecycle from scope through continual improvement.



SOC 2 is a continuous management program

The final report is a milestone. Controls must continue operating after the audit.

Figure 2. The SOC 2 lifecycle

5.1 Define the scope

Identify the service, boundaries, systems, people, data, locations, vendors, criteria, and period.

5.2 Describe the system

Document infrastructure, software, people, procedures, data, boundaries, commitments, vendors, and customer responsibilities.

5.3 Assess risk

Identify events that could prevent the organization from meeting its service and security objectives.

5.4 Build the control matrix

Connect each important risk to controls, owners, frequencies, evidence, and criteria.

5.5 Perform readiness

Test whether controls are designed, implemented, performed, and evidenced before the formal period.

5.6 Remediate gaps

Assign owners and due dates, correct weaknesses, and retain proof of completion.

5.7 Operate controls

Perform daily, monthly, quarterly, annual, and event-driven controls throughout the period.

5.8 Support auditor testing

Provide complete populations, selected samples, evidence, explanations, and timely responses.

5.9 Evaluate exceptions

Confirm facts, determine cause and impact, correct the problem, and prevent recurrence.

5.10 Issue and maintain

Review the draft, sign representations, receive the report, distribute it securely, and continue operating controls.

6. Scope, System Description, and Boundaries

A clear scope prevents missing systems, unnecessary work, and confusing audit results.

6.1 The five system components

Component	Questions to answer
Infrastructure	Which cloud accounts, servers, databases, networks, devices, and facilities deliver the service?
Software	Which applications, operating systems, utilities, code repositories, and tools support the service?
People	Which employees, contractors, departments, and administrators operate or support the service?
Procedures	Which processes govern access, changes, incidents, backups, vendors, and customer support?
Data	Which customer, confidential, operational, and personal information enters, moves through, or leaves the system?

6.2 Subservice organizations

A subservice organization is a vendor that performs important functions that support the service, such as cloud hosting, data center operations, payment processing, identity services, or customer communications.

- Carve-out method: the vendor's controls are excluded from the service auditor's testing, but the vendor and relevant responsibilities are described.
- Inclusive method: the relevant vendor controls are included in the description and examination.

6.3 Complementary User Entity Controls

Complementary User Entity Controls, or CUECs, are controls customers are expected to operate. Examples include protecting administrator accounts, configuring permissions correctly, reviewing customer-side activity, and removing former users.

6.4 Description criteria

- Nature of the service and principal service commitments
- System boundaries and major components
- Relevant criteria and controls
- Incidents and significant changes, when required
- Subservice organizations and the method used
- Complementary User Entity Controls
- Information necessary for readers to understand the system fairly

7. Complete Trust Services Criteria Breakdown

Plain-English summaries, manager actions, evidence, and helpful tools.

Important: These are educational summaries. Use the current AICPA criteria for authoritative wording and have the CPA firm confirm the final mapping.

7.1 CC1 — Control Environment

ID	Meaning	Manager action	Evidence	Helpful tools
CC1.1	Integrity and ethics	Set and enforce expected behavior.	Code of conduct, acknowledgments, investigations	CISO Assistant, policy repository
CC1.2	Independent oversight	Provide the board or governing body with useful risk information.	Board minutes, risk reports, security briefings	CISO Assistant, reporting tools
CC1.3	Structure and authority	Define reporting lines, responsibilities, and decision rights.	Organization chart, job descriptions, RACI	CISO Assistant
CC1.4	Competence	Hire, train, and retain people with suitable knowledge.	Training, qualifications, performance reviews	LMS, HR system
CC1.5	Accountability	Hold control owners responsible for assigned duties.	Owner register, escalations, corrective actions	CISO Assistant, ticketing

7.2 CC2 — Communication and Information

ID	Meaning	Manager action	Evidence	Helpful tools
CC2.1	Quality information	Identify reliable information needed for decisions.	Dashboards, metrics, reports, review records	Wazuh, Grafana
CC2.2	Internal communication	Communicate objectives, policies, incidents, and duties.	Notices, meetings, policy acknowledgments	Mattermost, LMS
CC2.3	External communication	Maintain suitable communication with customers, vendors, and authorities.	Customer notices, contracts, vendor messages	Ticketing, secure portals

7.3 CC3 — Risk Assessment

ID	Meaning	Manager action	Evidence	Helpful tools
CC3.1	Clear objectives	Define objectives precisely enough to identify risks.	Service commitments, security objectives	CISO Assistant
CC3.2	Risk identification	Identify, analyze, score, and treat risk.	Risk register, methodology, treatment plans	CISO Assistant
CC3.3	Fraud risk	Consider employee, contractor, customer, and management fraud.	Fraud assessment, segregation review	GRC platform, analytics
CC3.4	Significant change	Reassess risk after business, personnel, vendor, or technology changes.	Change-risk reviews, acquisition assessments	CISO Assistant, ticketing

7.4 CC4 — Monitoring

ID	Meaning	Manager action	Evidence	Helpful tools
CC4.1	Control evaluations	Perform continuing or separate evaluations of controls.	Internal testing, dashboards, review schedules	CISO Assistant, Wazuh

ID	Meaning	Manager action	Evidence	Helpful tools
CC4.2	Deficiencies	Report, assign, correct, and close control failures.	Findings register, remediation, retest	DefectDojo, CISO Assistant

7.5 CC5 — Control Activities

ID	Meaning	Manager action	Evidence	Helpful tools
CC5.1	Select controls	Connect controls to identified risks.	Risk-control matrix	CISO Assistant
CC5.2	Technology controls	Establish technology safeguards supporting objectives.	Configuration, access, change, monitoring records	Wazuh, Prowler, OpenSCAP
CC5.3	Policies and procedures	Approve expectations and explain how controls operate.	Policies, procedures, approvals, acknowledgments	Git, document repository

7.6 CC6 — Logical and Physical Access

ID	Meaning	Manager action	Evidence	Helpful tools
CC6.1	Access architecture	Use authentication, network boundaries, and access security.	Architecture, MFA settings, firewall rules	Keycloak, Prowler, Wazuh
CC6.2	User lifecycle	Approve new access and remove access when no longer authorized.	Requests, HR notices, disablement logs	Keycloak, osquery
CC6.3	Least privilege	Grant only the access required for job duties.	Roles, access reviews, privileged accounts	osquery, Prowler
CC6.4	Physical access	Restrict facilities and equipment to authorized people.	Badge lists, visitor logs, facility reviews	Physical access system
CC6.5	Asset disposal	Make information unreadable before reuse or disposal.	Sanitization logs, destruction certificates	Approved erase tools
CC6.6	External threats	Protect the system boundary from external attack.	Firewall reviews, intrusion alerts, network diagrams	Wazuh, Suricata
CC6.7	Information transfer	Authorize and protect information during transmission and movement.	Encryption, transfer logs, key records	GnuPG, TLS configurations
CC6.8	Malicious software	Prevent or detect unauthorized and malicious software.	Endpoint alerts, scans, investigations	Wazuh, ClamAV

7.7 CC7 — System Operations

ID	Meaning	Manager action	Evidence	Helpful tools
CC7.1	Vulnerabilities and configuration	Detect vulnerabilities and configuration weaknesses.	Scans, patch reports, tickets	Greenbone, OpenSCAP, Prowler
CC7.2	Monitoring	Monitor systems for anomalies, errors, and malicious activity.	Alerts, daily reviews, escalation records	Wazuh, Falco
CC7.3	Event evaluation	Determine whether a security event is an incident.	Triage notes, severity decision, ticket	TheHive, Wazuh
CC7.4	Incident response	Contain, investigate, correct, and communicate incidents.	Incident timeline, actions, communications	TheHive, Velociraptor
CC7.5	Recovery	Restore operations and improve after incidents.	Recovery records, lessons learned, follow-up	Backup tools, ticketing

7.8 CC8 — Change Management

ID	Meaning	Manager action	Evidence	Helpful tools
CC8.1	Authorized changes	Design, test, approve, deploy, and document changes.	Change tickets, tests, approvals, deployment logs	GitLab CE, Jenkins, Trivy, OPA

7.9 CC9 — Risk Mitigation

ID	Meaning	Manager action	Evidence	Helpful tools
CC9.1	Disruption risk	Reduce risks that could interrupt objectives and service.	Continuity plans, insurance, recovery strategies	CISO Assistant, monitoring
CC9.2	Vendor risk	Assess and monitor vendors and business partners.	Assessments, contracts, SOC reviews, ratings	CISO Assistant, Dependency-Track

7.10 A1 — Availability

ID	Meaning	Manager action	Evidence	Helpful tools
A1.1	Capacity	Monitor usage, performance, and future demand.	Capacity reports, scaling alerts, forecasts	Prometheus, Grafana, Zabbix
A1.2	Environmental and recovery resources	Use backups, redundancy, power, and recovery infrastructure.	Backup logs, redundancy diagrams, alerts	Restic, BorgBackup, Zabbix
A1.3	Recovery testing	Test disaster recovery and business continuity.	Exercise plan, results, corrective actions	Backup tools, ticketing

7.11 PI1 — Processing Integrity

ID	Meaning	Manager action	Evidence	Helpful tools
PI1.1	Processing objectives	Define complete, accurate, timely, and authorized processing.	Processing standards, commitments	Workflow documentation
PI1.2	Inputs	Validate incoming information and handle errors.	Input-validation logs, rejected items	Application logs, data-quality tools
PI1.3	Processing	Monitor calculations, workflows, and jobs.	Job logs, reconciliations, error records	Airflow, OpenSearch
PI1.4	Outputs	Validate and deliver outputs to intended recipients.	Output reviews, delivery logs	Application logs
PI1.5	Stored information	Maintain completeness and accuracy while information is stored.	Integrity checks, database controls	Wazuh, database audit logs

7.12 C1 — Confidentiality

ID	Meaning	Manager action	Evidence	Helpful tools
C1.1	Identify and protect	Classify confidential information and apply handling rules.	Inventory, classification, encryption, access	OpenMetadata, GnuPG, Wazuh
C1.2	Dispose	Securely destroy confidential information when no longer required.	Deletion logs, destruction records	Approved secure-erase tools

7.13 P1–P8 — Privacy

ID	Meaning	Manager action	Evidence	Helpful tools
P1.1	Notice	Explain privacy practices clearly.	Privacy notice, version, approval	Document repository
P2.1	Choice and consent	Provide choices and obtain consent when required.	Consent and opt-out records	Consent-management system
P3.1	Purposeful collection	Collect personal information only for identified purposes.	Data inventory, forms, purpose statements	OpenMetadata, DataHub
P3.2	Explicit consent	Obtain explicit consent for sensitive information when required.	Signed or electronic consent	Consent-management system
P4.1	Use	Use personal information only for approved purposes.	Access logs, approved uses	Wazuh, database logs
P4.2	Retention	Keep personal information only as long as needed.	Retention schedule, reviews	GRC platform
P4.3	Disposal	Delete personal information securely.	Deletion logs, approvals	Approved deletion tools

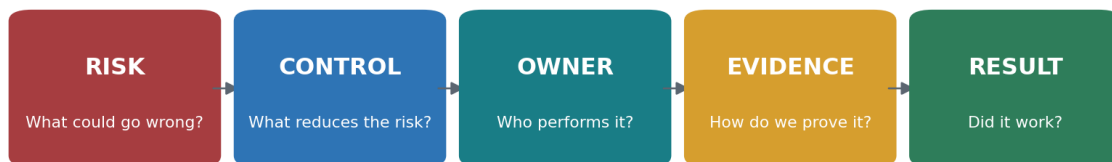
ID	Meaning	Manager action	Evidence	Helpful tools
P5.1	Access requests	Allow authenticated people to request their information.	Request register, identity verification, response	Ticketing
P5.2	Corrections	Allow inaccurate information to be corrected.	Correction requests and results	Ticketing
P6.1	Authorized disclosure	Disclose personal information with proper authority or consent.	Consent, legal basis, approval	Privacy register
P6.2	Disclosure records	Record authorized disclosures.	Disclosure register	GRC platform
P6.3	Unauthorized disclosure	Record and investigate unauthorized disclosures.	Incident and investigation records	TheHive, Wazuh
P6.4	Vendor privacy commitments	Require and assess suitable vendor commitments.	Contracts, DPAs, assessments	CISO Assistant
P6.5	Vendor incident notice	Require vendors to report suspected privacy incidents.	Contract clause, notification process	Vendor management
P6.6	Breach notification	Notify affected parties and authorities when required.	Decision, legal review, notices	Incident platform
P6.7	Disclosure accounting	Provide disclosure information when required.	Request and response records	Privacy register
P7.1	Data quality	Keep personal information accurate, complete, and current.	Validation and correction records	Data-quality tools
P8.1	Monitoring and complaints	Monitor privacy practices and resolve complaints.	Assessments, complaint log, corrective actions	CISO Assistant, ticketing

8. Practical SOC 2 Control Library

Common control areas, what they accomplish, and the evidence managers should expect.

Area	Example control	Expected evidence
Governance	Security policies are reviewed and approved annually.	Approved policy, version, owner, review date
Training	Personnel complete security training at hire and annually.	Completion report, population, exceptions
Onboarding	Access is approved before accounts are provisioned.	Request, approval, provisioning record
Termination	Access is disabled promptly after an approved termination notice.	HR notice, ticket, disablement timestamp
Access review	Privileged and production access is reviewed quarterly.	Complete population, review, removals
Vulnerability	Systems are scanned and findings are remediated by risk.	Scan, ticket, SLA, rescan
Patch management	Security patches are evaluated and installed according to risk.	Patch report, exceptions, approvals
Logging	Security logs are collected, protected, and reviewed.	Log settings, alerts, review record
Incident response	Incidents are identified, contained, investigated, and closed.	Ticket, timeline, actions, lessons learned
Change management	Production changes are tested and approved before deployment.	Ticket, test, approval, deployment
Backups	Backups run on schedule and restoration is tested.	Job logs, failures, restore test
Continuity	Recovery plans are exercised and improved.	Exercise, results, actions
Vendor management	Critical vendors are assessed before use and periodically.	Assessment, contract, SOC review
Data retention	Information is retained and deleted according to approved rules.	Schedule, deletion logs, exceptions
Encryption	Sensitive information is encrypted in transit and at rest.	Configuration, key controls, tests

8.1 Writing a testable control



If any link is missing, the control is not audit-ready.

Figure 3. Risk-to-result control chain

A control should identify the performer, activity, frequency, system or population, evidence, and review or approval. Avoid vague language such as ‘management reviews access regularly.’

Better control: The IT manager reviews all active production accounts quarterly. Unnecessary access is removed, and the completed review, approval, and corrective-action tickets are retained in the ticketing system.

9. Audit Evidence, Sampling, and Exceptions

How to collect reliable evidence and document what the auditor tested.

Evidence becomes stronger when it is reliable, reviewed, and acted upon

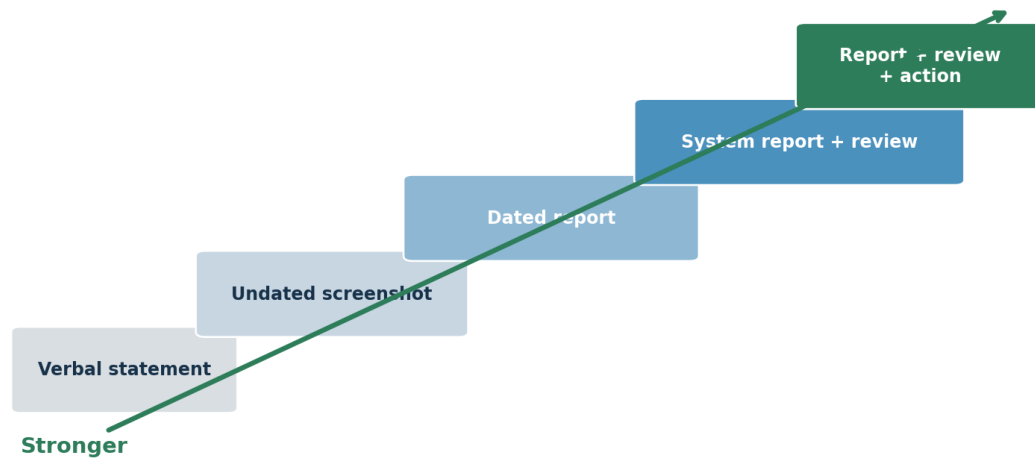


Figure 4. Evidence quality staircase

9.1 Evidence quality

- Complete
- Accurate
- Dated
- Connected to the control
- From a reliable source
- Reviewed by an authorized person
- Protected from improper alteration
- Retained for the required period

9.2 Populations and samples

A population is the complete group of items that could be tested, such as all employees hired during the period or all production changes. A sample is the set selected from that population. If the population is incomplete, the sample may not support a reliable conclusion.

9.3 Common evidence requests

Control	Possible evidence
Training	Employee population, assigned course, completion report, overdue follow-up
Access review	Complete user listing, reviewer comments, approval, removal tickets

Control	Possible evidence
Termination	HR notice, termination time, disablement logs, related ticket
Production change	Ticket, code review, testing, approval, deployment result
Vulnerability	Scan report, validated finding, ticket, rescan, risk exception
Backup	Automated logs, failure alert, response, restore-test evidence
Vendor review	Questionnaire, risk rating, contract, SOC report review

9.4 Exceptions

An exception is a difference between the stated control and what occurred. One exception does not automatically mean the entire examination fails. The auditor considers risk, frequency, cause, impact, compensating controls, and whether the issue indicates a broader problem.

- Confirm the facts.
- Identify the cause.
- Assess the impact.
- Correct the immediate issue.
- Prevent recurrence.
- Retain evidence of remediation.
- Communicate honestly with the auditor.

10. Open-Source Tools for SOC 2

What each tool does, when to use it, when not to use it, a safe first exercise, evidence, and common problems.

Methodology first: A tool can support a control, but it cannot create compliance, replace management judgment, or issue a SOC 2 report.

Tool	Area	Use	Evidence
CISO Assistant	GRC program management	Risks, controls, assessments, evidence, third-party risk, and audit tracking	Risk register, control status, findings, audit trail
Wazuh	Security monitoring	SIEM, endpoint events, file integrity, configuration, and alerts	Alerts, reviews, investigations, inventory
Prowler	Cloud security	Assess AWS, Azure, GCP, and Kubernetes configurations	Cloud findings, reports, remediation results
Greenbone/OpenVAS	Vulnerability scanning	Identify known network and system vulnerabilities	Scan report, affected assets, rescan
DefectDojo	Findings management	Import, deduplicate, assign, track, retest, and close findings	Owner, due date, remediation, closure
osquery	Endpoint visibility	Query users, software, processes, connections, and system state	User, software, and configuration reports
OpenSCAP	Configuration assessment	Compare Linux systems with machine-readable security baselines	Baseline report, failures, remediation
Falco	Runtime security	Detect suspicious host, container, and Kubernetes behavior	Alert, rule, event time, investigation
ZAP	Web application testing	Passive and authorized active testing of web applications	Test scope, findings, retest
Trivy	Code and container scanning	Find vulnerabilities, secrets, misconfigurations, and software components	Scan result, artifact version, remediation
Open Policy Agent	Policy as code	Enforce approved technical rules in applications and pipelines	Policy version, decision, pipeline result

10.1 CISO Assistant

Organizes GRC work and can map controls to SOC 2 and other frameworks.

Official documentation and setup: [Open the official CISO Assistant guide](#)

Quick start

Follow the official setup guide in an approved laboratory. Create a fictional organization, then add one risk, one control, one owner, and one evidence record. Review the record as if you were preparing it for an auditor.

Why and when to use it

- Use it to maintain risks, controls, owners, evidence, assessments, vendors, and corrective actions.
- Do not treat a green status as proof without reviewing the attached evidence.

First safe exercise

Create a fictional organization, enter the risk 'former employees retain access,' create a termination control, assign an owner, and attach fictional evidence.

Common problems

Incomplete ownership, outdated evidence, and controls marked complete without proof.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.2 Wazuh

Collects security events and monitors endpoints and cloud workloads.

Official documentation and setup: [Open the official Wazuh guide](#)

Quick start

Build an all-in-one laboratory deployment and connect one test endpoint. Turn on one approved use case, create a harmless test event, review the alert, and save the alert plus the analyst's review notes.

Why and when to use it

- Use file-integrity monitoring, centralized alerts, endpoint inventory, and configuration checks.
- Do not collect alerts without a documented review and escalation process.

First safe exercise

Monitor a test folder in a laboratory, modify a harmless text file, review the alert, and document the expected cause.

Common problems

Alert overload, poor time synchronization, missing agents, and no evidence of human review.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.3 Prowler

Assesses cloud environments for security weaknesses and best-practice gaps.

Official documentation and setup: [Open the official Prowler guide](#)

Quick start

Choose the cloud provider and create a dedicated read-only test identity. Run a narrowly scoped assessment, validate one result, export the report, correct the issue in the lab, and run the check again.

Why and when to use it

- Use a dedicated read-only identity and record the assessed accounts and regions.
- Do not assume every failed check is automatically a SOC 2 exception.

First safe exercise

Run it in a laboratory cloud account, validate one finding, correct it, and retain before-and-after reports.

Common problems

Excess permissions, incomplete scope, false positives, and reports without management review.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.4 Greenbone/OpenVAS

Scans networks and systems for known vulnerabilities.

Official documentation and setup: [Open the official Greenbone/OpenVAS guide](#)

Quick start

Install the Community Edition in a laboratory and update its vulnerability feed. Add only an approved test target, run a safe scan, validate one result, correct it, and rescan to show closure.

Why and when to use it

- Use authenticated scanning where approved to improve visibility.
- Never scan an unapproved production or third-party system.

First safe exercise

Scan one laboratory virtual machine, validate a finding, correct it, rescan, and document closure.

Common problems

Outdated feeds, fragile targets, false positives, and findings closed without rescan.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.5 DefectDojo

Combines and tracks findings from many security tools.

Official documentation and setup: [Open the official DefectDojo guide](#)

Quick start

Create a laboratory product, engagement, and test. Import a sample security report, review duplicate findings, assign one finding to an owner, record the fix, retest it, and then close it with proof.

Why and when to use it

- Use it to assign owners, deadlines, risk decisions, retests, and verified closure.
- Do not close a finding only because someone says it was fixed.

First safe exercise

Import a laboratory scan, validate one finding, assign it, document remediation, and close it after retesting.

Common problems

Duplicate findings, inconsistent severity, missing owners, and unsupported closure.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.6 osquery

Let's an analyst ask questions about endpoints using SQL-style queries.

Official documentation and setup: [Open the official osquery guide](#)

Quick start

Install osquery on a laboratory endpoint and open the interactive shell. Run a basic query against the users or programs table, export the result, and record the query, host, date, reviewer, and purpose.

Why and when to use it

- Use it to report users, software, processes, network connections, and file information.
- Limit access to reports because endpoint information can be sensitive.

First safe exercise

Open osqueryi and run `SELECT username, uid, directory FROM users;` on a laboratory endpoint.

Common problems

Different tables by operating system, incomplete fleet coverage, and exports without review.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.7 OpenSCAP

Evaluates Linux configurations against defined baselines.

Official documentation and setup: [Open the official OpenSCAP guide](#)

Quick start

Install the scanner and suitable security content on a laboratory Linux host. Select the correct profile, run an assessment, export the report, fix one approved setting, and compare the new result.

Why and when to use it

- Use it to measure hardening and generate repeatable reports.
- Do not apply automatic remediation to production without testing.

First safe exercise

Assess a laboratory Linux host, generate an HTML report, correct one approved setting, and compare results.

Common problems

Wrong baseline, unsupported content, application impact, and unapproved remediation.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.8 Falco

Detects unusual runtime behavior across hosts, containers, and Kubernetes.

Official documentation and setup: [Open the official Falco guide](#)

Quick start

Deploy Falco on a laboratory host, container, or test cluster. Begin with the default rules, create a harmless event that should alert, inspect the context, and save the rule, event time, and review decision.

Why and when to use it

- Use rules to alert on unexpected shells, sensitive file changes, or privilege activity.
- Tune rules without disabling important detections merely to reduce noise.

First safe exercise

Trigger a harmless standard rule in a local test container and document the resulting alert.

Common problems

False positives, missing context, unowned alerts, and no integration with incident handling.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.9 ZAP

Tests web applications through passive observation and authorized active scanning.

Official documentation and setup: [Open the official ZAP guide](#)

Quick start

Install ZAP and proxy a browser through it while using a local training application. Review passive findings first. Use active scanning only with written authorization, and export the scope, findings, and retest report.

Why and when to use it

- Start with passive scanning in a deliberately vulnerable local application.
- Active scanning can modify data or interrupt service and requires written authorization.

First safe exercise

Proxy a browser through ZAP while using a local training application, review passive findings, and export a report.

Common problems

Testing outside scope, false positives, unsafe production scans, and treating automation as a complete penetration test.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.10 Trivy

Scans code, container images, Kubernetes, and infrastructure-as-code.

Official documentation and setup: [Open the official Trivy guide](#)

Quick start

Install Trivy and scan a pinned laboratory image or test repository. Save the tool version, target version, settings, and full report. Validate one finding, document the response, and scan again after the fix.

Why and when to use it

- Record tool version, date, target digest or version, and scan configuration.
- Protect results because secret detection may reveal sensitive values.

First safe exercise

Run trivy image nginx: latest in a laboratory, select one finding, and document how it would be handled.

Common problems

Stale vulnerability data, unpinned images, ignored findings, and exposed secrets in reports.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.11 Open Policy Agent

Applies technical policy decisions as code.

Official documentation and setup: [Open the official Open Policy Agent guide](#)

Quick start

Install the OPA command-line tool or use its official learning environment. Write one small policy and test input, evaluate allowed and denied cases, save the policy version and results, and review changes like application code.

Why and when to use it

- Use version-controlled rules to prevent unsafe deployments or configurations.
- Review and test policy code like application code.

First safe exercise

Create a local rule that denies an example resource missing an owner label, test allowed and denied inputs, and save the results.

Common problems

Rules that block legitimate work, missing tests, undocumented exceptions, and uncontrolled policy changes.

Evidence reminder: Record the tool version, date, approved scope, configuration, complete result, reviewer, decisions, corrective actions, and retest.

10.12 Tool governance checklist

1. Obtain management approval before placing a tool into production.
2. Document the business purpose, owner, scope, data collected, and retention period.
3. Use least-privilege service accounts and protect credentials.
4. Verify software sources, releases, checksums, signatures, and update procedures.
5. Test changes in a laboratory before production deployment.
6. Define who reviews results, how quickly, and how findings are escalated.
7. Protect reports because they may reveal vulnerabilities, identities, or secrets.
8. Review whether the tool continues to produce complete and reliable information.

11. Manager's SOC 2 Playbook

The questions, meetings, metrics, and decisions a manager should control.

11.1 Questions for every control owner

1. What risk does this control reduce?
2. Who performs it?
3. How often?
4. When was it last completed?
5. Where is the evidence?
6. Were there exceptions?
7. Who reviewed the result?
8. Is corrective action required?
9. Can part of it be automated?
10. Who is the backup owner?

11.2 Monthly dashboard

Area	Manager question	Status
Completion	Were all scheduled controls performed?	Green / Yellow / Red
Evidence	Which controls lack reliable evidence?	Green / Yellow / Red
Exceptions	What failed, why, and with what impact?	Green / Yellow / Red
Remediation	Are corrective actions on schedule?	Green / Yellow / Red
Access	Were terminations and access reviews completed?	Green / Yellow / Red
Vulnerabilities	Are critical findings handled within policy?	Green / Yellow / Red
Incidents	Were events triaged and incidents resolved?	Green / Yellow / Red
Vendors	Did any critical vendor's risk change?	Green / Yellow / Red

11.3 Status meanings

Green: completed on time with acceptable evidence.

Yellow: completed, but evidence or follow-up is incomplete.

Red: missed, failed, or has a significant unresolved exception.

11.4 Common management mistakes

Treating SOC 2 as an IT-only project.

Selecting unnecessary categories.

Starting formal testing before readiness work is complete.

Copying policies that do not match operations.

Writing controls that teams cannot perform.

Leaving controls without named owners.

Performing controls without retaining evidence.

Ignoring vendors and cloud dependencies.

Hiding known weaknesses.

Believing an automation platform replaces judgment.

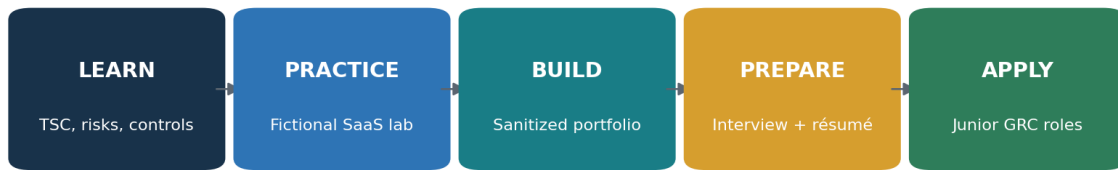
11.5 Monthly SOC 2 meeting agenda

1. Confirm scheduled controls completed since the last meeting.
2. Review missing, weak, or late evidence.
3. Evaluate new control exceptions and their business impact.
4. Review overdue corrective actions and remove blockers.
5. Discuss significant system, personnel, vendor, and service changes.
6. Review security incidents, privacy events, and important vulnerabilities.
7. Confirm upcoming control deadlines and backup owners.
8. Record decisions, accepted risks, owners, and due dates.

Meeting output: The meeting should produce decisions and assigned actions—not only a status presentation. Retain the agenda, attendees, decisions, owners, and due dates.

12. From Beginner to Junior SOC 2/GRC Analyst

A safe and honest route from learning the framework to demonstrating entry-level ability.



Be honest: label portfolio work as a laboratory project, not professional audit experience.

Figure 5. Junior analyst pathway

12.1 Job titles

Junior GRC Analyst
 Security Compliance Analyst
 SOC 2 Readiness Analyst
 IT Audit Associate
 Technology Risk Analyst
 Third-Party Risk Analyst
 Cybersecurity Assurance Analyst
 Compliance Operations Analyst
 Junior Security Controls Analyst

Search warning: "SOC Analyst" usually means a Security Operations Center analyst, not a SOC 2 compliance analyst. Include GRC, compliance, assurance, IT audit, security controls, technology risk, and SOC 2 in searches.

12.2 Typical junior work

- ✓ Request evidence from control owners.
- ✓ Confirm that evidence covers the correct period.
- ✓ Organize files and screenshots securely.

- ✓ Compare evidence with the control description.
- ✓ Update risk and control matrices.
- ✓ Prepare populations and selected samples.
- ✓ Document testing procedures and results.
- ✓ Record exceptions and track remediation.
- ✓ Take clear client or control-owner meeting notes.
- ✓ Protect confidential customer and audit information.

12.3 Essential knowledge

- ✓ Type I versus Type II
- ✓ Five Trust Services Categories
- ✓ CC1 through CC9
- ✓ Design versus operating effectiveness
- ✓ Risk, control, evidence, and exception
- ✓ Population and sample
- ✓ Control owner and frequency
- ✓ CUECs and subservice organizations
- ✓ Carve-out and inclusive methods
- ✓ Management assertion and system description
- ✓ Auditor independence and opinion types

12.4 Professional skills

- ✓ Write clearly and professionally.
- ✓ Ask questions without blaming people.
- ✓ Follow up politely and consistently.
- ✓ Take accurate notes.
- ✓ Admit when something is not understood.
- ✓ Never alter evidence to make it appear stronger.
- ✓ Meet deadlines and escalate important problems.
- ✓ Explain technical matters in business language.

Strong junior answer: I would understand the risk and control, obtain the complete population, select the required sample, examine reliable evidence, document exactly what I tested, and escalate any exception. I would never hide a problem or assume a control worked without evidence.

13. Fictional SaaS Laboratory and Portfolio

A complete practice environment using fictional or properly sanitized information.

13.1 SecureCloud Learning Services

- ✓ Provides a cloud-based customer portal.
- ✓ Has 25 employees and a remote workforce.
- ✓ Uses Microsoft Azure and several cloud vendors.
- ✓ Stores confidential customer information.
- ✓ Has developers, administrators, and customer-support staff.
- ✓ Is preparing for its first SOC 2 Type II examination.

Project 1 — Scope

Define service, boundaries, components, data, vendors, locations, and criteria. Deliverable: two-page scope document.

Project 2 — Risk register

Create at least ten risks with likelihood, impact, owner, treatment, and connected controls.

Project 3 — Control matrix

Create 15–20 testable controls with owners, frequencies, criteria, and evidence.

Project 4 — Evidence package

Create fictional evidence for onboarding, termination, access review, changes, scanning, training, backups, vendors, and incidents.

Project 5 — Open-source tools

Use CISO Assistant, Wazuh, Prowler, Trivy, or OpenSCAP in an isolated laboratory and document the results.

Project 6 — Control testing

Test a fictional quarterly access review, document the procedure, result, exception, and corrective action.

13.2 Portfolio ethics

Never publish real employer, employee, customer, vendor, security, or audit information. Clearly label the work as a fictional laboratory project. Do not claim professional audit experience that you do not have.

13.3 Honest résumé example

SOC 2 Readiness Laboratory Project: Built a fictional SaaS SOC 2 readiness program, including scope definition, risk assessment, Trust Services Criteria mapping, a 20-control risk and control matrix, sample evidence, control testing, and remediation tracking. Used open-source GRC, monitoring, cloud-assessment, and vulnerability-management tools in an isolated laboratory.

14. Thirty-Day Learning Plan

A realistic month of study, practice, portfolio work, and interview preparation.

Week	Focus	Required output
Week 1	SOC 2 foundations, Type I/II, categories, CC1–CC9	One-page framework summary and flashcards
Week 2	Risk, controls, evidence, populations, samples, exceptions	Risk register and 15-control matrix
Week 3	CISO Assistant plus two technical tools in a lab	Sanitized reports and evidence workbook
Week 4	Control testing, portfolio, résumé, and interviews	Completed portfolio and practiced answers

14.1 Daily habit

1. Study one criterion.
2. Write one control.
3. Identify one evidence example.
4. Explain the topic aloud in plain language.
5. Add one item to the fictional portfolio.

15. Interview Preparation

Questions and short answers for junior analysts and managers.

What is SOC 2?

An independent CPA examination of a service organization's description and controls relevant to security and selected trust categories.

Type I versus Type II?

Type I examines design at a date. Type II also examines whether controls operated effectively throughout a period.

What makes evidence reliable?

It is complete, accurate, dated, connected to the control, from a reliable source, and shows review and action.

How would you test a termination?

Obtain the complete termination population, select the sample, compare HR termination time with account disablement, and document the result.

What is an exception?

A difference between the stated control and what occurred. It must be evaluated for cause, impact, frequency, and remediation.

What if evidence is missing?

Confirm the request, ask the owner, inspect alternate reliable evidence, document the gap, and escalate rather than assume.

What is a CUEC?

A control the customer is expected to operate for the service organization's controls to achieve their objectives.

How do tools support SOC 2?

They collect data, detect issues, enforce technical rules, and produce reports, but people must review and act on the results.

15.1 Manager's 60-second answer

Interview response: I treat SOC 2 as an operating risk program. I define the scope and commitments, identify risks, map them to testable controls, assign owners and frequencies, verify evidence quality, monitor exceptions, and remediate gaps before formal testing. During the examination, I protect independence, provide complete populations and evidence, and communicate issues honestly. After issuance, the control program continues.

16. Templates and Checklists

Practical structures that can be copied into an approved organizational system.

16.1 Risk register fields

1. Risk ID
2. Asset or process
3. Threat
4. Business impact
5. Likelihood
6. Impact
7. Inherent risk
8. Existing controls
9. Residual risk
10. Treatment
11. Owner
12. Due date
13. Status

16.2 Control matrix fields

1. Control ID
2. Risk
3. Control statement
4. Criterion
5. Owner
6. Frequency
7. Population
8. Evidence
9. Reviewer
10. Status
11. Exception
12. Corrective action

16.3 Evidence-request template

Request: Please provide the complete production-user population and evidence of management's quarterly review for April 1 through June 30. The evidence should identify the reviewer, completion date, exceptions found, and related corrective actions.

16.4 Evidence review checklist

- ✓ Correct organization and system

- ✓ Correct examination period
- ✓ Complete population
- ✓ Reliable source
- ✓ Performer and reviewer identified
- ✓ Date visible
- ✓ Exceptions documented
- ✓ Corrective actions supported
- ✓ Sensitive information protected

16.5 Exception record

Field	Required information
Control	Control ID and statement
Condition	What happened
Expected	What should have happened
Cause	Why the difference occurred
Impact	Risk and affected systems or records
Correction	Immediate action
Prevention	Longer-term improvement
Owner and date	Responsible person and due date
Closure	Retest and approval evidence

16.6 Manager's pre-audit checklist

- ✓ Scope and criteria approved.
- ✓ System description current.
- ✓ Risk assessment approved.
- ✓ Every control has an owner and frequency.
- ✓ Control calendar is current.
- ✓ Evidence is organized and protected.
- ✓ Populations can be generated completely.
- ✓ Known gaps have treatment plans.
- ✓ Vendors are assessed.
- ✓ Incidents and significant changes are evaluated.
- ✓ Management understands the assertion.
- ✓ Audit communication and escalation paths are defined.

17. Glossary

Plain-English definitions of important SOC 2, audit, risk, and technical terms.

AICPA. American Institute of Certified Public Accountants, the organization that develops the SOC reporting framework and Trust Services Criteria.

Assertion. Management’s written statement accepting responsibility for the system description and controls.

Attestation. An independent practitioner’s examination and report on information provided by another party.

Availability. The system is available for operation and use in accordance with commitments.

Carve-out method. A report method that excludes the subservice organization’s controls from the service auditor’s testing while describing relevant responsibilities.

Compensating control. Another control that reduces a risk when the primary control is missing or does not operate as intended.

Confidentiality. Protection of information designated as confidential.

Control. A policy, process, activity, or technical safeguard used to reduce risk.

Control design. Whether a control, if performed as described, is capable of addressing the related risk.

Control owner. The person responsible for performing or overseeing a control.

Corrective action. Work performed to fix an identified problem and prevent recurrence.

CUEC. Complementary User Entity Control—a control the customer is expected to operate.

Evidence. Reliable information demonstrating that a control was performed and reviewed.

Exception. A difference between the control description or expected result and what actually occurred.

Inclusive method. A method that includes relevant subservice-organization controls in the system description and examination.

Inherent risk. Risk before considering the effect of controls.

Management representation. Written confirmations management provides to the auditor near completion of the engagement.

Materiality. The importance of a matter to the decisions of intended report users.

Operating effectiveness. Whether a control operated as designed, by appropriate people, throughout the relevant period.

Population. The complete group of items from which audit samples may be selected.

Privacy. Proper collection, use, retention, disclosure, and disposal of personal information.

Processing integrity. Processing that is complete, valid, accurate, timely, and authorized.

Readiness assessment. A review performed before the formal examination to identify and correct gaps.

Residual risk. Risk remaining after controls are considered.

Risk. The possibility that an event will prevent an objective from being achieved.

Risk and control matrix. A structured record connecting risks, controls, owners, frequencies, evidence, and criteria.

Sample. Items selected from a complete population for testing.

Security. Protection against unauthorized access, use, or damage that could affect system commitments.

Service commitment. A promise made to customers about how the service will operate or protect information.

Service organization. An organization that provides services to customers or user entities.

Subservice organization. A vendor used by the service organization to perform important functions supporting the service.

System boundary. The people, processes, technology, data, and locations included in the system being described and examined.

Trust Services Criteria. The AICPA criteria used to evaluate controls relevant to security and selected additional categories.

Type I. A SOC 2 examination of description and control design as of a specified date.

Type II. A SOC 2 examination that also addresses operating effectiveness over a specified period.

User entity. A customer organization using the service organization's service.

18. Subject Index

An alphabetical guide to the major topics in this manual. References point to sections rather than page numbers so the index remains useful if the document is edited.

Topic	Sections	Topic	Sections
Access reviews	7.6, 8, 9.3, 13	Open Policy Agent	10.11
Auditor independence	4, 12.3	OpenSCAP	10.7
Availability	2, 7.10	osquery	10.6
Carve-out method	6.2, 17	Privacy	2, 7.13
Change management	7.8, 8, 10.11	Processing integrity	2, 7.11
CISO Assistant	7, 10.1, 13	Prowler	10.3
Common Criteria	7.1–7.9	Readiness assessment	5.5, 17
Confidentiality	2, 7.12	Risk and control matrix	5.4, 8.1, 13
Control design	3.1, 8.1, 17	Risk assessment	5.3, 7.3
Control evidence	8, 9, 16.4	Sampling	9.2, 12.2
Control owner	4, 8.1, 11.1	Scope	5.1, 6
CUECs	6.3, 12.3, 17	Security	2, 7.1–7.9
DefectDojo	10.5	Subservice organizations	6.2, 17
Disaster recovery	7.10, 8	System description	5.2, 6
Evidence quality	9.1, 16.4	Trivy	10.10
Exceptions	5.9, 9.4, 16.5	Trust Services Categories	2, 7
Falco	10.8	Type I	3, 17
Greenbone/OpenVAS	10.4	Type II	3, 17
Incident response	7.7, 8	Vendor management	7.9, 8
Inclusive method	6.2, 17	Wazuh	10.2
Junior analyst	12–15	ZAP	10.9
Manager dashboard	11.2		

19. Official References and Further Study

Authoritative framework sources and official project documentation used for further study.

[AICPA SOC Suite of Services](https://www.aicpa-cima.com/resources/landing/system-and-organization-controls-soc-suite-of-services) — <https://www.aicpa-cima.com/resources/landing/system-and-organization-controls-soc-suite-of-services>

[AICPA Trust Services Criteria](https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022) — <https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022>

[AICPA SOC 2 Description Criteria](https://www.aicpa-cima.com/resources/download/get-description-criteria-for-your-organizations-soc-2-r-report) — <https://www.aicpa-cima.com/resources/download/get-description-criteria-for-your-organizations-soc-2-r-report>

[AICPA Illustrative SOC 2 Type II Report](https://www.aicpa-cima.com/resources/download/illustrative-service-auditors-soc-2-r-type-2-report) — <https://www.aicpa-cima.com/resources/download/illustrative-service-auditors-soc-2-r-type-2-report>

[CISO Assistant documentation](https://intuitem.gitbook.io/ciso-assistant) — <https://intuitem.gitbook.io/ciso-assistant>

[Wazuh documentation](https://documentation.wazuh.com/current/) — <https://documentation.wazuh.com/current/>

[Prowler documentation](https://docs.prowler.com/) — <https://docs.prowler.com/>

[Greenbone Community documentation](https://greenbone.github.io/) — <https://greenbone.github.io/>

[DefectDojo documentation](https://docs.defectdojo.com/) — <https://docs.defectdojo.com/>

[osquery documentation](https://osquery.readthedocs.io/) — <https://osquery.readthedocs.io/>

[OpenSCAP](https://www.open-scap.org/) — <https://www.open-scap.org/>

[Falco documentation](https://falco.org/docs/) — <https://falco.org/docs/>

[ZAP documentation](https://www.zaproxy.org/docs/) — <https://www.zaproxy.org/docs/>

[Trivy documentation](https://trivy.dev/) — <https://trivy.dev/>

[Open Policy Agent documentation](https://openpolicyagent.org/docs) — <https://openpolicyagent.org/docs>

Final reminder: Frameworks, tools, laws, and professional guidance change. Verify current official sources before using this manual for a real engagement.